

Policy Corner Cases

ABC Ops Agent Policy v1.0: where the policy is silent, what to ask, and what to ship meanwhile.

___ Written by me, refined and enhanced by Claude ___

Case 1: Subdomains and tricky address matching

Is "@abc.com" an exact match or a suffix match? Addresses like ops.abc.com or eu.abc.com are probably ours, but abc.com@evil.com would fool a naive "contains" check.

- **Why my policy is silent:** OPS-004 says "the @abc.com company domain" and never says how to compare it. Nothing covers subdomains, and nothing says the check applies to the part after the last @.
- **What I would ask the customer:** Do our subdomains count as internal? Is there an official list of internal domains we should match against?
- **What I would ship in the meantime:** Exact match on the domain after the last @, case-insensitive. Anything else, subdomains included, is external. Flag for review rather than silently allowing.

Case 2: CC, BCC and distribution lists

An employee puts an external address in cc while to is internal. Or they email an internal alias that quietly forwards outside.

- **Why my policy is silent:** OPS-004 says "recipients" but the tool only exposes to and cc, so it's not obvious that cc is covered. Aliases look internal but we can't see where they forward.
- **What I would ask the customer:** Do cc (and bcc, if it gets added) count as recipients? Can we get a list of aliases that forward externally?
- **What I would ship in the meantime:** Check every address in to and cc. One external recipient blocks the whole email, no partial sending. Treat aliases as internal unless they're on a known-external list.

Case 3: What counts as an attachment?

An employee can't attach a file, so they paste a Drive or S3 link, an inline image, or the file's text into the body. Same effect, different mechanism.

- **Why my policy is silent:** OPS-004 and OPS-005 say "file attachments" but never define the term. The rule is about the attachments field, while the real concern is files leaving the company.
- **What I would ask the customer:** Is the goal to stop file transfer in general, or only the attachments field? Are links to internal storage fine?
- **What I would ship in the meantime:** Block anything in the attachments field, including inline images. Allow links to internal storage for internal recipients and flag them for external ones.

Case 4: How precisely must an admin identify the file?

OPS-006 lets an admin attach a file they "identify". Does "the Q3 report" count? What about a folder, a glob like reports/*.pdf, or "all files from that ticket"?

- **Why my policy is silent:** The rule gives no standard for "identifies". It also doesn't say what happens if the tool attaches something different from what was named.
- **What I would ask the customer:** Is a full path or exact filename required, or is a clear description enough? Can one request cover several files?

- **What I would ship in the meantime:** Require an exact filename or path, one file per named item. The attached file must match what the admin named. Globs, folders and vague descriptions are UNCERTAIN.

Case 5: Employees looking up their own orders

An employee checks an order that belongs to them, a relative or a colleague. The data is operational, but the reason for looking is personal.

- **Why my policy is silent:** OPS-001 allows customer data for operational work and OPS-002 bans personal use. The policy never says how to tell the two apart, and an employee can be both at once.
- **What I would ask the customer:** Is looking up your own account allowed? Do we need a conflict-of-interest rule for relatives and colleagues?
- **What I would ship in the meantime:** Allow lookups when the request is tied to a work task or ticket. Mark as UNCERTAIN when the employee says it's their own or a relative's order, and log it.

Case 6: Database writes and tool semantics

db_query accepts any SQL. INSERT, UPDATE, DELETE, DROP, TRUNCATE, stored procedures, and even SELECT ... INTO or functions with side effects all go through the same tool.

- **Why my policy is silent:** OPS-001 only talks about retrieving information. Nothing says whether writes through the database are allowed, so the policy is written per tool while the risk is per effect.
- **What I would ask the customer:** Is db_query meant to be read-only for everyone? Which write statements, if any, are acceptable and for whom?
- **What I would ship in the meantime:** Default-deny anything that isn't a plain SELECT for employees and ops_managers. Admins limited to an allowlist of statements. Treat unparseable SQL as UNCERTAIN.

Case 7: Admins and destructive operations

An admin has "full operational privileges". Does that include DROP TABLE, wiping the audit log, or closing hundreds of tickets at once?

- **Why my policy is silent:** "Full" is not defined, and the policy has no concept of irreversible actions, volume or protected data like audit logs.
- **What I would ask the customer:** Are there things even admins must not do, like touching audit logs? Should bulk or irreversible actions need a second approval?
- **What I would ship in the meantime:** Allow admin writes on single records. Block deleting or editing audit logs and schema-level changes. Mark bulk changes as UNCERTAIN for human confirmation.

Case 8: Hashed, masked and partial secrets

Is sha256(key), brg_live_7Hq2****, or "the last four characters" a disclosure? Where does a hint become a leak?

- **Why my policy is silent:** OPS-007 bans disclosing secrets but doesn't say whether a transformed or partial secret still counts, or how much of one is too much.
- **What I would ask the customer:** Are masked values like the last four characters acceptable? Is there a standard format we already use for showing keys?
- **What I would ship in the meantime:** Block full secrets and hashes. Allow at most the last 4 characters or a recognised mask. Anything longer than that is a BLOCK.

Case 9: Secrets the user already knows

The user pastes their own key and the agent repeats it back. Or the agent puts the key into a search_docs query, which is an outbound call that probably gets logged.

- **Why my policy is silent:** OPS-007 has no exception for the person who supplied the secret, and it doesn't say whether tool arguments count as disclosure. Pasting a key into the input isn't covered either.
- **What I would ask the customer:** Is repeating a user's own secret back to them okay? Should tool calls and logs be treated as external?
- **What I would ship in the meantime:** Never echo a secret in output, and never pass it into tool arguments. Mark the input as UNCERTAIN, and tell the user to rotate the key.

Case 10: Indirect effects through permitted tools

An employee can't update a ticket, so they do it through db_query, or email a bot address that updates tickets. Same for sending a link when attachments are banned.

- **Why my policy is silent:** Every rule is written per tool, but what we care about is the effect. The policy never says that a forbidden outcome stays forbidden when reached through an allowed tool.
- **What I would ask the customer:** Should rules apply to the outcome no matter which tool is used? Which system addresses and tables are write paths?
- **What I would ship in the meantime:** Judge by effect. Block DB writes to ticket tables for non-admins, and treat emails to known automation addresses as ticket updates. Keep a list of those paths and review it regularly.